

Nombre: Luis Alberto Vargas Gonzalez

Fecha: 26/01/2026

Actividad y unidad: U2 A1: Práctica: Tipos de malware y métodos de
protección

Clase: Seguridad de Software.

Maestría en Ciberseguridad.

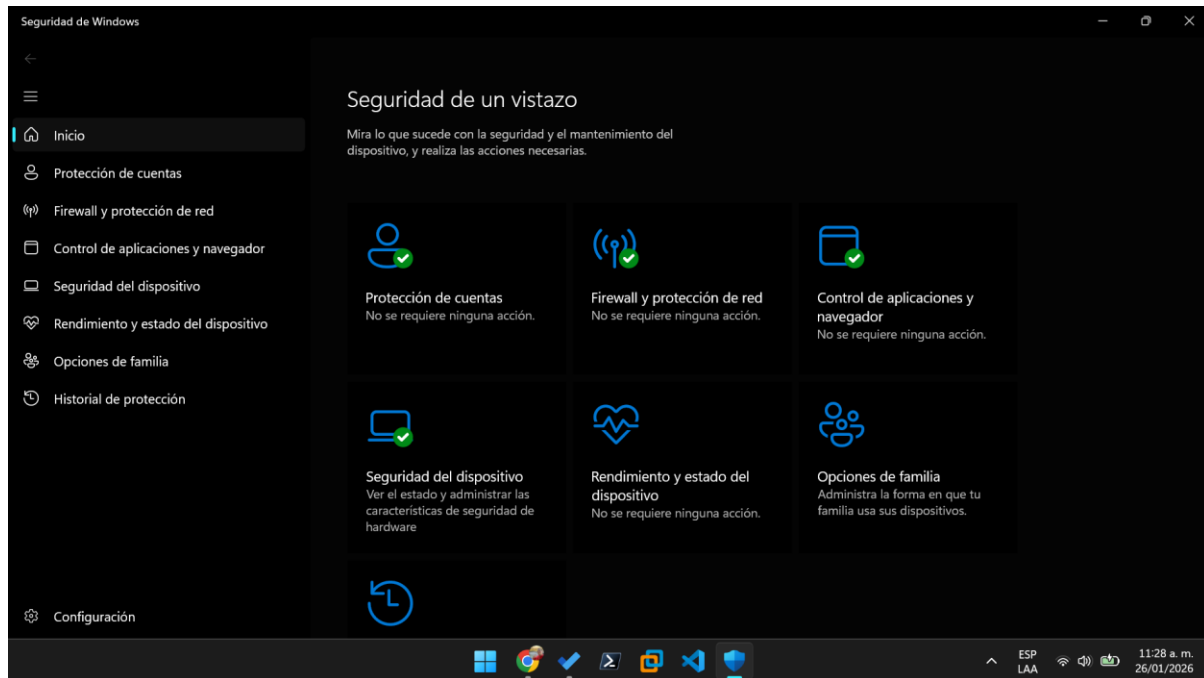
INTRODUCCIÓN

El panorama actual de las ciberamenazas se caracteriza por una evolución constante de software malicioso (malware) diseñado con el objetivo primordial de generar lucro. Desde virus tradicionales que requieren un anfitrión hasta gusanos capaces de propagarse de forma autónoma, la protección de dispositivos personales requiere un enfoque multicapa que combine tecnología y educación.

En esta práctica nos centraremos en identificar, analizar y explicar los diferentes tipos de malware que existen, junto con sus riesgos de ataque y para ello, es necesario conocer de igual manera las estrategias de defensa y protección que a nivel personal funcionan en dispositivos móviles como tabletas, smartphones, laptops, así como en dispositivos de escritorio como PC, servidores NAS, etc.

Análisis Personal de Seguridad.

Uso de Software de protección de Endpoints (Antivirus)



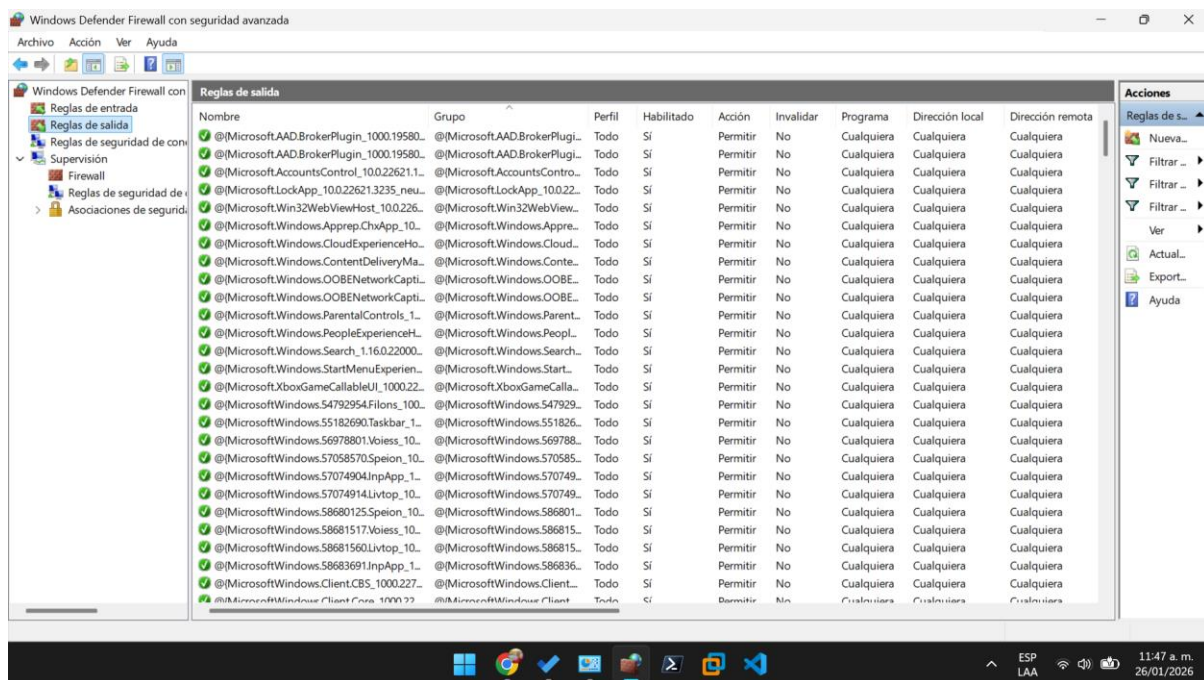
Como punto de inicio en su forma más básica, tenemos el antivirus en nuestros endpoints de usuario final, en donde; como sabemos, cualquier antivirus trabaja por medio de firmas de virus, los cuales son guardados en una Database especial dentro del sistema operativo (en este caso por tratarse de Windows Defender) o en un servidor de Base de datos en los casos de antivirus de compañías externas, estas firmas de virus se van alojando constantemente en esta BD para poder ser comparadas con cada archivo, carpeta o enlace que descargue el usuario en su Endpoint, es por ello que dichas firmas se van actualizando constantemente, al menos una vez al día en el caso de Windows Defender, 1 vez cada 3 días en el caso de algunos otros proveedores o incluso 1 análisis cada 12 hrs en ciertos ambientes estrictos.

```

00402FF0: 00 00 00 00.00 00 00 00.00 00 00 00.00 00 00 00.00 00 00 00 kernel132.dll Wi
00403000: 6B 65 72 6E.65 6C 33 32.2E 64 6C 6C.00 57 69 5E Exec RegisterSer
00403010: 45 78 65 63.00 52 65 67.69 73 74 65.72 53 65 72 uiceProcess.sxlm
00403020: 76 69 63 65.50 72 6F 63.65 73 73 00.75 72 6C 6D on.dll -----
00403030: 6F 6E 2E 64.6C 6C 00 2D.2D 2D 2D 2D.2D 52 4C 44 RLD
00403040: 2D 2D 2D 2D.2D 2D 2D 2D.2D 2D 2D 00.00 52 4C 44 downloadToFileA -
00403050: 6F 77 6E 6C.6F 61 64 54.6F 46 69 6C.65 41 00 2D -----
00403060: 2D 2D 2D 2D.2D 2D 2D 2D.2D 2D 2D 2D.2D 2D 2D http://nursingk
00403070: 00 68 74 74.70 3A 2F 2F.6E 75 72 73.69 6E 67 6B ore.a.co.kr/image
00403080: 6F 72 65 61.2E 63 6F 2E.6B 72 2F 69.6D 61 67 65 s/inf2.php?v=s x
00403090: 73 2F 69 6E.66 32 2E 70.68 70 3F 76.3D 73 00 78 xxxxxxxxxxxxxx http
004030A0: 78 78 78 78.78 78 78.78 78 78 00.68 74 74 70 ://nursingkorea.
004030B0: 3A 2F 2F 6E.75 72 73 69.6E 67 6B 6F.72 65 61 2E co.kr/images/med
004030C0: 63 6F 2E 6B.72 2F 69 6D.61 67 65 73.2F 6D 65 64 s.gif c:\459\ex
004030D0: 73 2E 67 69.66 00 63 3A.5C 34 35 39.5C 2E 65 78 e c:\boot.bak
004030E0: 65 00 63 3A.5C 62 6F 6F.74 2E 62 61.6B 00 00 00
004030F0: 00 00 00 00.00 00 00 00.00 00 00 00 00 00 00
00403100: 00 00 00 00.00 00 00 00.00 00 00 00 00 00 00
00403110: 00 00 00 00.00 00 00 00.00 00 00 00 00 00 00

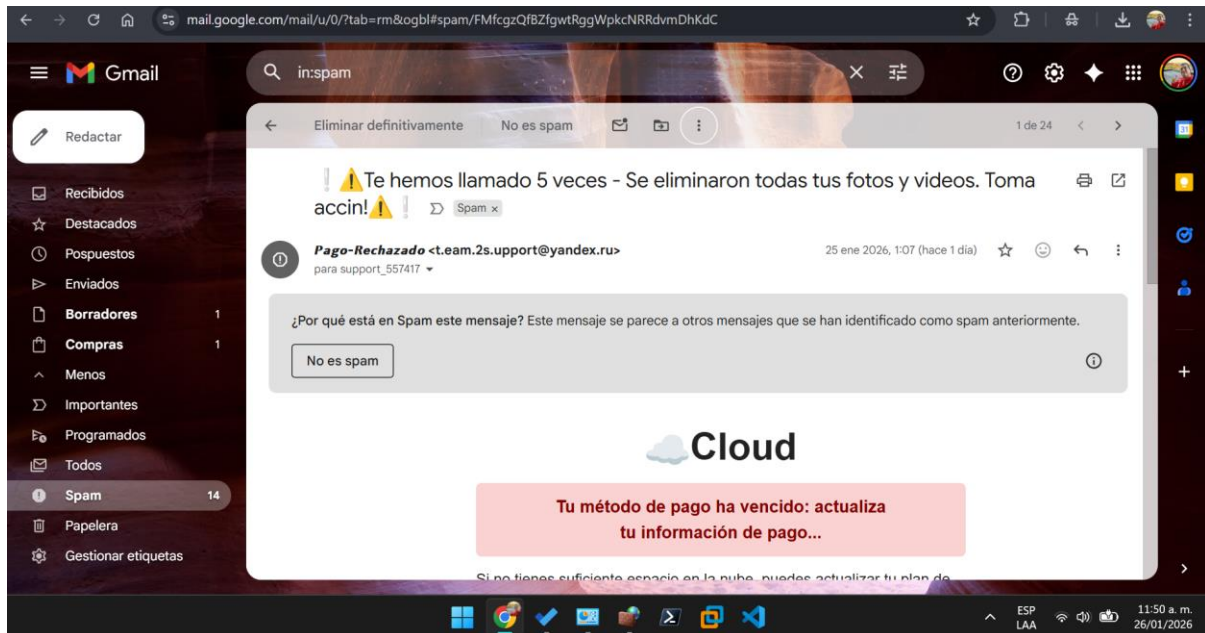
```

Este firewall administrado por Windows Defender, así como el antivirus, nos permite identificar tráfico sospechoso de distintos puertos conocidos como, por ejemplo; 443, 80, 21, 22 o 53 , lo cual nos permite poder identificar las operaciones que pueden estar realizando virus del tipo Troyano en el equipo que de cierto modo no es detectable por el antivirus puesto que muchos Troyanos como su



El análisis de las reglas de entrada y salida permite verificar la superficie de ataque del sistema. Al implementar una política de 'Deny by Default' para conexiones entrantes que no coincidan con una regla específica, se mitigan ataques de escaneo de puertos y movimientos laterales de troyanos que intentan establecer sesiones en puertos como el 21 (FTP) o 22 (SSH) sin autorización. Esta configuración es vital para proteger la integridad de los servicios locales frente a procesos en segundo plano difíciles de detectar.

Filtro de correo Spam en Gmail.



Esta herramienta es esencial para cualquier administrador de sistemas, programador o incluso ingeniero en ciberseguridad, puesto que ninguna dirección de correo electrónico ya sea personal o empresarial está exenta de recibir Spam ya sea publicitario o maligno que incluyan ataques de ingeniería social, como podemos ver en el ejemplo de arriba, en donde tenemos un claro signo de ingeniería social, donde una dirección de correo sospechosa está suplantando al equipo de soporte técnico de Apple y en este caso del servicio iCloud , y me solicitan el pago inmediato (generar un sentido de urgencia) de la suscripción mensual de iCloud , o en su defecto perderé para siempre mis fotos y videos personales de mis dispositivos Apple.

Como sabemos, el Filtro AntiSpam utiliza IA, Machine Learning evaluando la reputación del remitente (quien envía el correo) ya sea con su Ip o el dominio de correo.

Funcionando con las siguientes técnicas:

Autenticación del Remitente: Verifica la identidad del remitente mediante protocolos estrictos:

SPF (Sender Policy Framework): Comprueba si la IP tiene permiso para enviar correos en nombre del dominio.

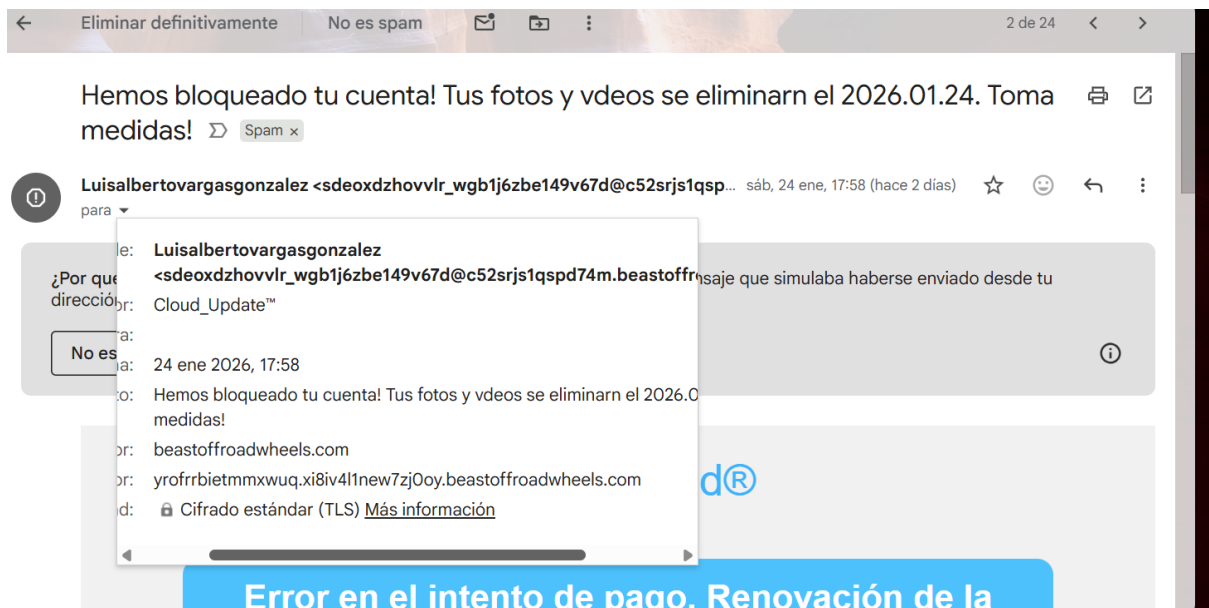
DKIM (DomainKeys Identified Mail): Valida la firma criptográfica para asegurar que el mensaje no fue alterado.

DMARC (Domain-based Message Authentication, Reporting, and Conformance): Indica qué hacer si falla la autenticación.

Análisis Heurístico y de Contenido: Examina palabras clave, enlaces sospechosos, uso de acortadores de URL y estructuras HTML comunes en ataques de phishing.

Reputación (IP y Dominio): Analiza el historial de envío de la dirección IP y el dominio. Las fuentes con historial de spam son bloqueadas o limitadas (rate limiting).

Análisis Estadístico: Compara patrones actuales con datos históricos (hasta 180 días) para identificar anomalías.



Identificación de Riesgos y Métodos de Mitigación

Dispositivo/Servicio	Riesgo Potencial	Descripción del riesgo	Método de Mitigación
PC/Laptop	Ransomware	Virus que cifra archivos y pide un pago generalmente en criptomonedas para desbloquearlos	Uso de Backups en nube y uso de herramientas como Malwarebytes para detectar los virus que no

			hayan sido detectados por los antivirus.
Smartphone	Buffer Overflow	Vulnerabilidad en librerías de medios que permite ejecución remota de código.	Mantener el SO actualizado y evitar instalar apps de sitios no oficiales.
Red Doméstica (WIFI y Cableado)	Spyware/Adware	Software que registra pulsaciones de teclas (Keyloggers) o hábitos de compra.	Educación del usuario y uso de "Whitelisting" (lista blanca) de aplicaciones permitidas.

Los riesgos identificados en la tabla anterior, como el Ransomware y Phishing, tienen una evidencia directa en el análisis de seguridad realizado. Por ejemplo, en las capturas del filtro AntiSpam de Gmail, se observa un ataque de ingeniería social que utiliza la suplantación de identidad (iCloud) y el sentido de urgencia para comprometer datos financieros. La mitigación mediante el análisis de reputación de IP y protocolos como SPF/DKIM/DMARC es la respuesta técnica necesaria para reducir la probabilidad de éxito de estos vectores de ataque.

Reflexión y Respuesta a Preguntas

¿Cuáles son las debilidades de tus dispositivos?

Son múltiples las debilidades que un dispositivo de cualquier marca puede presentar, desde diseños inseguros por parte de desarrolladores de apps o de sitios web hasta vulnerabilidades dentro del kernel de cada Sistema Operativo, sin embargo, hay una especialmente crítica que permite que, aunque se tenga una estrategia de Defensa por capas o en profundidad, puedan ser burladas muchas de estas defensas; el **factor humano**, ese factor humano depende mucho de la manera de comportarse de las personas, y como adquieren y procesan las experiencias de su día a día en el mundo de la tecnología, y a pesar de que el factor humano es diferente en cada persona, y su nivel de daño es diferente, es un factor que no se puede mitigar en un 100%, y depende mucho de la situación que se esté viviendo en ese momento, es decir, un personal de IT como yo, tendrá su nivel de detección de amenazas más alto si trabaja en un ambiente sano y colaborativo, que un trabajador que este en un ambiente altamente exigente, estresante y en ciertas ocasiones hasta intimidante para trabajar, en donde dicho trabajador se centrará más en la supervivencia del día a día en su puesto laboral que en detectar amenazas digitales que puedan afectar su rol dentro de una organización.

¿Estas debilidades en qué riesgo te ponen?

Estas debilidades me ponen en una multitud de riesgos en el día a día, siendo los riesgos los siguiente:

1. Pérdida de productividad.
2. Robo de datos financieros personales.
3. Adición de mi equipo a una botnet para ataques DDOS
4. Daño a mi reputación dentro del área de IT.
5. Daño económico en caso de necesitar pagar rescates de información.

Sin embargo, de todos estos riesgos antes mencionados, considero que la **pérdida de productividad** y el **robo de datos financieros personales** son los más altamente probables en un escenario en donde se trabaja con el rol que yo perfilo (SysAdmin) y en un ambiente hogareño en donde uso mis equipos para poder mantenerme actualizado con noticias, cursos, certificaciones y diversas actividades como seminarios, presentaciones online a las que accedo constantemente para entrenar mis habilidades con las nuevas herramientas y tecnologías que han ido surgiendo con el paso del tiempo, por lo que es vital mantener la productividad en los estándares actuales , y la protección de mis datos financieros en medios seguros para poder mantener el ritmo de crecimiento profesional y personal similar al ritmo de crecimiento y de cambio en la industria IT y en especial del área de Sistemas y SysAdmin.

¿Qué acciones podrías tomar para mitigar esas debilidades?

Son múltiples las estrategias para poder mitigar las debilidades antes mencionadas, sin embargo, no todas son igualmente efectivas ante los diversos escenarios que se viven en el transcurso de la vida profesional, por lo tanto; implementar una **Estrategia de Educación Estructural** es ideal para mantener una defensa firme en tantos frentes que hay que proteger (sistemas webs , sistemas operativos, aplicaciones financieras, de inversión y bancarias por mencionar algunas) siendo las actualizaciones automáticas de versiones de Software , extremadamente relevante en esta estrategia para mitigar nuevas y graves vulnerabilidades dentro de Sistemas Operativos, aplicaciones web, apps de uso frecuente como bancarias y financieras , enfocándonos además en concientizarnos a nivel profesional y personal de la importancia de seguir estudiando y analizando las nuevas y complejas estrategias de los cibercriminales para transgredir la privacidad del usuario.

La mitigación no se limita a la instalación de parches; implica una gestión de vulnerabilidades que proteja el kernel del Sistema Operativo y las librerías de aplicaciones financieras. Las actualizaciones automáticas son críticas para corregir defectos de software que permiten ataques de *Buffer Overflow* o ejecución remota de código. Al mantener el SO actualizado, se implementan protecciones modernas a nivel de software que dificultan la explotación de vulnerabilidades antes de que el usuario sea consciente de ellas.

¿Tu solución actual es suficiente?

En ciberseguridad no hay ninguna estrategia que funcione para el 100% de las variables, casos, variantes de software y por supuesto, que pueda batir completamente las constantes y cada vez más evolucionadas amenazas de los cibercriminales por lo que el uso de firewalls, sistemas de protección de terminales como los antivirus, el uso de filtrado en correos no garantiza que una amenaza, una vulnerabilidad nueva o un nuevo virus ultra evolucionado no aparezca y mucho menos que no pueda infectar mis equipos , esto debido además de que la producción de nuevos sistemas computacionales se ha ido complejizando a tal grado que ahora hay miles de millones de carpetas y archivos para todos los Sistemas Operativos , para proyectos webs profesionales por igual , hace aún más difícil la tarea de proteger todo de manera perfecta y permanente , existen desde hace unos pocos años nuevas y mejores tecnologías de detección de intrusos en redes como los Next Generation Firewalls y los EDR y XDR de última generación que traen por defecto aprendizaje automático , machine y Deep learning , sin embargo todas estas tecnologías son y seguirán siendo imperfectas y también serán perfectibles , lo cual indica que tienen todavía un largo camino para solucionar lagunas legales, técnicas, vulnerabilidades que traigan en sí por adicionar y complejizar los dispositivos , por lo que la carrera de la ciberseguridad es una carrera de fondo , no importa si vas rápido o lento, es una carrera que nunca termina , a mayor cantidad de piezas de software, de librerías, de componentes , mayor cantidad de posibles

vulnerabilidades y defectos que atenten contra la Triada CIA (Confidencialidad, Integridad y Disponibilidad).

En conclusión, aunque mi solución actual basada en firmas y firewalls estatales es robusta, la evolución hacia tecnologías EDR (Endpoint Detection and Response) es el siguiente paso necesario para mitigar amenazas que no dependen de firmas conocidas, protegiendo así la Tríada CIA (Confidencialidad, Integridad y Disponibilidad) en un entorno de software cada vez más complejo.

Referencias Bibliográficas.

1. Cengage Learning. (2017). Hands-On Ethical Hacking and Network Defense (3rd ed., Chapter 3). [Material de clase]. Universidad Autónoma de Guadalajara / Arizona State University.